CYBER INTELLIGENCE REPORT

CTI-2026-0420-VERCEL

Vercel 보안 침해 사건 분석

——— AI SaaS 공급망 공격 및 ShinyHunters 위협 평가 ———

Context.ai 경유 Google Workspace OAuth 탈취 및

잠재적 NPM/GitHub 소프트웨어 공급망 리스크

분류 (Classification)	TLP:GREEN / 대외 공유 가능
심각도 (Severity)	**HIGH — 공급망 공격 잠재력 · 개발자 생태계 광범위 영향**
대상 산업 (Target Sector)	클라우드 개발 플랫폼 · SaaS · Web3/블록체인 프로젝트
침해 일자 (Incident Date)	2026년 4월 18–19일 (공식 공개: 2026-04-19)
위협 행위자 (Threat Actor)	ShinyHunters 자처 (UNC6240/UNC6661 연계 가능성)
작성일 (Publication)	2026년 4월 20일
발행 (Publisher)	Dennis Kim https://github.com/gameworkerkim/CYBER-THREAT-INTELLIGENCE-REPORT

1. 경영진 요약 (Executive Summary)

2026년 4월 19일, 미국의 대표적 프런트엔드 클라우드 개발 플랫폼 Vercel Inc.가 자사 내부 시스템에 대한 비인가 접근을 공식 확인하였다. 해당 침해는 Vercel 자체의 취약점이 아니라, 한 내부 직원이 사용하던 AI 에이전트 플랫폼 'Context.ai'의 침해로부터 출발하여 Google Workspace OAuth 토큰 탈취 → 환경 변수(Environment Variables) 열거 → 내부 환경 측면 이동(Lateral Movement) 으로 이어진 전형적인 제3자 SaaS 공급망 공격 체인이다.

공격자 ShinyHunters를 자처하는 위협 행위자는 BreachForums에 Vercel 내부 데이터베이스, 접근 키, 소스코드, NPM 토큰, GitHub 토큰, 직원 계정 정보를 200만 달러(약 29억 원)에 판매한다는 게시물을 공개했으며, Vercel CEO Guillermo Rauch는 해당 공격의 속도와 내부 시스템 이해도로 볼 때 'AI에 의해 크게 가속화되었을 가능성이 높다'고 공개적으로 평가했다.

> ⚠️ 핵심 리스크:
> NPM 토큰 및 GitHub 토큰이 실제로 탈취되었다면, 공격자는 Vercel 자체를 넘어 Next.js 기반 생태계 전체의 배포 파이프라인에 악성 코드를 주입할 수 있으며, 이는 SolarWinds, Salesloft-Drift 사례와 같은 전역적 소프트웨어 공급망 공격으로 확전될 잠재력을 가진다. Vercel은 공식적으로 Next.js·Turbopack·오픈소스 프로젝트 공급망은 안전하다고 밝혔으나, 영향 범위 조사는 진행 중이다.

핵심 판단 (Key Judgments)

#	판단	근거 및 신뢰도
KJ-1	초기 접근은 Context.ai의 침해에서 기인했으며, Vercel 자체의 제품 취약점은 아니다.	Vercel CEO 공식 성명 및 Vercel 보안 공지(Security Bulletin) 명시. 신뢰도: 높음(High).
KJ-2	'민감하지 않음(non-sensitive)'으로 분류된 환	CEO가 X(트위터)에서 직접 인정. '비민감' 환경 변수는 저장 시 암호화되지 않아 열람 가능. 신뢰도: 높음.

	경 변수가 권한 상승의 결정적 피벗 지점이 되었다.	
KJ-3	NPM/GitHub 토큰 탈취가 확인될 경우, 글로벌 JS 생태계에 대한 2차 공급망 공격이 실제화될 수 있다.	BreachForums 판매 게시물의 주장에 기반. Vercel은 공급망 감사 결과 Next.js·Turbopack 안전 확인. 신뢰도: 중간(Medium).
KJ-4	BreachForums 판매자의 'ShinyHunters 자처'는 본인의 브랜드 차용 가능성이 있으나, TTP는 2025–2026 캠페인과 일관된다.	ShinyHunters 연계 행위자들이 BleepingComputer에 본 사건 연루를 부인. Mandiant는 UNC6240·UNC6661·UNC6671로 클러스터링. 신뢰도: 중간.
KJ-5	본 사건은 'AI SaaS → 인증 평면(Identity Plane) → 개발 생태계' 로 이어지는 공격 패턴의 대표 사례가 될 것이다.	Salesloft-Drift(2025.08), Gainsight, Mixpanel, Anodot 등 동일 패턴의 연쇄 사건 존재. 신뢰도: 높음.

2. 사건 개요

2.1 피해 주체 프로파일

항목	내용
회사명	Vercel Inc.
핵심 사업	JavaScript 프레임워크 중심 클라우드 호스팅 및 배포 인프라 (Next.js 개발사)
대표 제품	Next.js · Turbopack · Serverless Functions · Edge Computing · CI/CD Pipeline
IPO 진행 상황	2026년 IPO 준비 중 (매출 240% 성장 보도 수일 전)
침해 공개 플랫폼	공식 보안 공지 (vercel.com) + CEO X(트위터) 공개 · BreachForums 판매 게시물

수사·조력 기관	Google Mandiant (사고 대응) · 기타 보안 전문 기관 · 법 집행 기관 통보

2.2 침해 경로 요약 (Attack Chain Summary)

공격은 크게 5단계로 전개되었다. 각 단계는 Vercel의 공식 보안 공지 및 CEO Guillermo Rauch가 공개한 사건 설명에 기반한다.

단계	명칭	상세 내용
Step 1	**Third-Party Compromise**	AI 에이전트 플랫폼 Context.ai가 먼저 침해되어 Google Workspace OAuth 앱 권한이 공격자 통제하에 편입됨.
Step 2	**Account Takeover (ATO)**	Context.ai를 사용하던 Vercel 직원 1인의 Google Workspace 계정이 OAuth 연동 채널을 통해 탈취됨.
Step 3	**Lateral Movement**	탈취한 직원의 Google Workspace ID로 Vercel 내부 환경(대시보드 및 관리 환경)에 접근.
Step 4	**Env Var Enumeration**	개발자가 '비민감(non-sensitive)'으로 지정한 환경 변수를 열거·열람. 이 변수들은 저장 시 비암호화 상태.
Step 5	**Privilege Escalation + Exfil**	열거된 환경 변수 내의 시크릿·토큰 정보로 추가 권한 상승 및 데이터 반출. 이후 BreachForums 판매 시도.

> 📌 본 공격 체인의 핵심은 '**인증(Identity)**'이 공격 표면의 새로운 중심이 되었다는 점이다. 공격자는 Vercel의 네트워크 경계를 뚫지 않았다. OAuth 연동된 SaaS 하나의 침해가 Google Workspace → Vercel 관리 콘솔로 '측면 이동'하는 경로가 되었다. 이는 Salesloft-Drift 사건(2025.08)과 구조적으로 동일하다.

3. 사건 타임라인 (Incident Timeline)

본 사건의 공개된 주요 이벤트를 시간순으로 정리한다. 모든 시각은 기사 보도 및 CEO 공개 발언을 기준으로 한다.

일시 (UTC / ET)	이벤트
시점 미공개 (사전)	Context.ai 침해 발생. 보안 연구원이 Vercel 측에 문제를 제보. Vercel 내부에서 즉시 조사 착수.
2026-04-19 02:02 ET	BreachForums 관리자 계정이 'Vercel Database Access Key & Source Code - 19 Apr' 라는 제목으로 판매 게시물 등록. 판매가 200만 달러(최저 50만 달러 BTC), '선착순 1인 판매' 조건 명시.
2026-04-19 (오후)	Vercel, 공식 보안 공지 'Vercel April 2026 security incident' 발표. '제한된 수의 고객에게 영향을 미친 보안 사고'임을 인정하고 영향 받은 고객에 직접 통지 시작.
2026-04-19 18:14 ET	Vercel, IoC(침해지표) 공개. Context.ai의 Google Workspace OAuth App ID 공식 지정: 110671459871-30f1spbu0hptbs60cb4vsmv79i7bbvqj.apps.googleusercontent.com
2026-04-19 19:21 ET	Vercel CEO Guillermo Rauch, X(트위터)에 상세 사건 설명 공개. Context.ai 침해 → Google Workspace → Vercel 환경 변수 경로 명시.
2026-04-20 04:08 UTC	CEO, Next.js · Turbopack · 오픈소스 프로젝트 공급망 감사 결과 '안전'을 확인. BreachForums 측의 'Next.js 공급망 리스크' 주장 반박.
2026-04-20 (본 리포트)	Mandiant 주도 사고 대응 진행 중. '판매자 측이 Telegram에서 Vercel에 직접 몸값을 요구했다'는 주장 순환. Vercel은 협상 여부 미확인.

4. 공격 벡터 및 기술 분석

4.1 Context.ai 의 역할과 OAuth 위임 공격

Context.ai는 기업 워크플로우 자동화를 위한 AI 에이전트 플랫폼으로, Google Workspace와 OAuth 기반으로 연동되어 사용자의 이메일·캘린더·드라이브 등에 위임된 접근 권한(scope)을 획득한다. 본 사건에서 공격자는 Context.ai 자체의 시스템 혹은 OAuth 앱 크리덴셜을 침해함으로써, 해당 앱에 동의한 모든 Google Workspace 사용자의 토큰을 간접 확보할 수 있는 위치에 섰다.

이 구조의 본질적 위험성은 다음과 같다:

위험 요소	기술적 설명
OAuth 토큰의 장기성	refresh token은 사용자 로그아웃이나 비밀번호 변경으로 자동 무효화되지 않는다. 토큰 탈취 시 공격자는 MFA를 우회한 지속적(persistent) 접근을 유지한다.
2차 SaaS 횡적 확산	Google Workspace 계정 탈취는 Sign-in with Google에 연동된 모든 SaaS(Vercel, Slack, Figma 등)로의 ATO로 확장된다.
'보이지 않는' 공격 표면	OAuth 앱 사용은 관리자 가시성이 낮고, 앱 허가 후에는 로그 기록이 제한적이다. 사용자가 AI 도구를 자율적으로 연동하는 Shadow IT 문제와 결합된다.
AI 에이전트의 권한 증폭	AI 플랫폼은 '효율성'을 명분으로 광범위한 scope(`gmail.readonly`, `drive` 등)를 요구하는 경향이 있어, 단일 침해의 폭발 반경(blast radius)이 크다.

4.2 '비-민감(non-sensitive)' 환경 변수의 취약성

Vercel은 모든 고객 환경 변수를 저장 시(at rest) 암호화한다는 원칙을 고수한다. 다만 개발자 편의를 위해 '민감(sensitive)' 과 '비민감(non-sensitive)' 두 가지 분류를 제공하며, 후자로 표기된

변수는 암호화되지 않은 평문(plaintext) 으로 조회 가능하다. CEO는 이 '비민감' 분류가 공격자의 권한 확장 피벗으로 악용되었음을 공식 인정했다.

> 🔑 **실무적 함의**:
> 많은 개발자가 RPC 엔드포인트, 내부 API URL, 외부 서비스 ID, 분석 키 등을 '비민감'으로 분류한다. 그
> 러나 이들 값은 공격자에게 내부 아키텍처 지도(map)를 제공하고, 일부는 별도 서비스 호출 시 별도 시크릿이 없어도 데이터에 접근 가능한 수준의 권한을 부여한다.
>
> 특히 Web3 프로젝트에서 RPC 엔드포인트·Graph API 키는 '비민감'으로 오분류되는 경향이 매우 강하다.

4.3 주장된 데이터 유형 및 공급망 파급효과

BreachForums 판매자가 제시한 증거 및 주장에 따르면, 유출 데이터는 다음을 포함하는 것으로 알려진다. 단, Vercel은 소스코드 도난을 공식 확인하지 않았으며, 스크린샷은 내부 IDP(Identity Provider) 사용자 스키마 성격에 가깝다.

데이터 유형	공격자 주장	Vercel 공식 입장	공급망 위험도
직원 계정 정보 (580건)	공개 (이름·이메일·활동 시각)	일부 노출 가능성 인정	🟡 **중간**
내부 데이터베이스 스키마	스크린샷 제시	미확인	🟡 **중간**
환경 변수 (비민감)	접근 주장	공식 인정	🔴 **높음**
NPM 토큰	판매 주장	미확인 · 감사 결과 '안전'	🔴 **매우 높음**
GitHub 토큰	판매 주장	미확인 · 감사 결과 '안전'	🔴 **매우 높음**

소스코드	판매 주장	부인 (미확인)	🟠 **높음**
API 키 (고객)	판매 주장	일부 크리덴셜 노출 통지	🔴 **높음**
민감 환경 변수 (암호화)	접근 불가 주장 없음	접근 흔적 없음	🟢 **낮음**

5. 위협 행위자 분석: ShinyHunters

5.1 개요 및 2026 년 활동

ShinyHunters는 2020년경 등장한 데이터 탈취·판매 중심의 사이버 범죄 브랜드로, 초기에는 BreachForums 중심의 대량 DB 판매 활동을 주도하였다. 2024년 이후 클라우드 SaaS 플랫폼 기반의 협박형(extortion) 공격으로 전환하며 2026년 현재 가장 활발한 기업 대상 데이터 탈취 단체 중 하나로 평가된다. Google Mandiant(GTIG)는 ShinyHunters를 자처하는 활동을 단일 단체가 아닌 UNC6040, UNC6240, UNC6661, UNC6671 등 복수 클러스터로 추적한다.

5.2 2025–2026 주요 캠페인 요약

시기	캠페인	핵심 TTP
2024 (Snowflake)	AT&T, Ticketmaster, Santander 등 100+ 기관	Snowflake 고객 계정 크리덴셜 스터핑 공격. MFA 미적용 계정 집중 공격.
2025.08 (Drift)	Salesloft Drift → 760+ Salesforce 인스턴스	Drift OAuth 토큰 탈취 → 연동된 Salesforce·Google Workspace 계정 광범위 접근. Cloudflare·Palo Alto·Zscaler·Proofpoint 피해.
2025.11 (Mixpanel)	PornHub·OpenAI 등 분석 데이터 유출	Mixpanel 직원 대상 스미싱(smishing) 기반 분석 데이터셋 반출.
2026.01 (Vishing)	Okta·기업 SSO 대상 vishing	IT 지원 사칭 음성 피싱으로 SSO + MFA 코드 탈취, 자체 단말 MFA 등록.
2026.03	Salesforce Experience	Mandiant의 AuraInspector 오픈소스 감사 도구를 무기

(Salesforce)	Cloud 300-400개 기업	화. /s/sfsites/aura 엔드포인트 비인증 질의로 CRM 데이터 반출.
2026.03 (TELUS)	TELUS Digital 1PB 데이터 탈취	통신·BPO 데이터 · FBI 배경조사 정보 포함. 몸값 6,500만 달러 요구.
2026.04 (Anodot)	Rockstar Games Snowflake (Anodot 경유)	Anodot SaaS 분석 플랫폼을 경유한 고객 Snowflake 접근. 동일한 '제3자 SaaS → 핵심 데이터' 패턴.
2026.04.19 (Vercel)	**Vercel (Context.ai 경유) — 본 사건**	**AI 에이전트 플랫폼 OAuth 침해 → Google Workspace → Vercel 환경 변수. 2025–2026 패턴의 AI-전환판.**

5.3 공격 패턴 공통분모

ShinyHunters-branded 활동의 2025-2026 캠페인은 다음 공통 요소를 반복적으로 보인다. 본 Vercel 사건은 이러한 패턴의 자연스러운 발전형이다.

#	공통 TTP	본 Vercel 사건 적용
1	제3자 SaaS를 최초 접점으로 사용	✅ Context.ai
2	OAuth/SSO 토큰 악용으로 MFA 우회	✅ Google Workspace OAuth
3	SaaS 간 측면 이동(cloud-to-cloud)	✅ Workspace → Vercel 관리환경
4	민감 데이터 탈취 후 72시간 내 몸값 요구	✅ BreachForums 200만 달러 판매·협박
5	DLS(Data Leak Site) 및 포럼 동시 노출	✅ BreachForums + Telegram 병행
6	피해자 브랜드 신뢰도 훼손 레버리지	✅ Vercel IPO 직전 타이밍 공격

> 2026년 4월 19일 BleepingComputer 보도에 따르면, ShinyHunters 그룹에 연계된 최근 공격자들이 본 Vercel 사건에의 관여를 부인하였다.
> 이는 'ShinyHunters' 브랜드가 더 이상 단일 조직을 지칭하지 않으며, 다른 위협 행위자가

> 신뢰성 증폭을 위해 차용하는 사례도 상당히 발생 중임을 시사한다. 귀속(attribution) 판단은 Mandiant의 최종 분석 결과를 기다릴 필요가 있다.

6. 침해 지표 (Indicators of Compromise)

다음 IoC는 Vercel 공식 보안 공지(2026-04-19) 및 관련 보도를 통해 확인된 것이다. Google Workspace 관리자는 아래 OAuth 앱 ID를 즉시 감사해야 한다.

6.1 Google Workspace OAuth Application (핵심 IoC)

유형	값
OAuth Client ID	`110671459871-30f1spbu0hptbs60cb4vsmv79i7bbvqj.apps.googleusercontent.com`
연관 서비스	Context.ai (AI 에이전트 플랫폼)
위험성	해당 앱에 사용자 동의가 이루어진 경우, 공격자가 해당 사용자 맥락에서 Google Workspace API에 접근 가능.

6.2 관찰된 TTP (MITRE ATT&CK 매핑)

ATT&CK ID	Tactic / Technique	본 사건 적용
T1199	Trusted Relationship	Context.ai 신뢰 관계 악용
T1528	Steal Application Access Token	Google Workspace OAuth 토큰 탈취
T1550.001	Use Alternate Authentication: App Token	OAuth 토큰으로 Vercel 직원 계정 가장
T1078.004	Valid Accounts: Cloud Accounts	정상 직원 Vercel 계정을 사용한 내부 접근
T1580	Cloud Infrastructure Discovery	Vercel 내부 환경 변수 열거
T1552.001	Credentials in Files	'비민감' 환경 변수 내 시크릿 수집

T1567	Exfiltration Over Web Service	데이터 반출 및 BreachForums 판매
T1657	Financial Theft / Extortion	200만 달러 몸값 요구 및 Telegram 협박

6.3 감사 권고 쿼리

Google Workspace 관리자는 다음 위치에서 해당 OAuth App 사용 이력을 확인해야 한다:

- Admin Console → Security → API controls → Domain-wide delegation
- Admin Console → Security → API controls → Manage Third-Party App Access
- Admin Console → Reports → Audit log → OAuth Log Events
- Users Report → Security → Connected Applications (per-user)

7. 대응 조치 및 보안 권고사항

본 권고사항은 Vercel 공식 조치, CEO 공개 성명, Mandiant 및 **업계 관례(NIST SP 800-61, 800-207)에 기반**한다. 우선순위(P0=즉시, P1=24시간, P2=7일)로 구분한다.

7.1 Vercel 고객 대상 P0 (즉시 조치)

#	조치 항목	설명
P0-1	시크릿 순환(Rotation)	Vercel 대시보드에 등록된 모든 API 키, 토큰, DB 크리덴셜, 비밀번호 즉시 재발급. 특히 NPM/GitHub 토큰 최우선.
P0-2	환경 변수 재분류	모든 '비민감(non-sensitive)' 환경 변수를 감사하여 시크릿을 포함하는 것은 'Sensitive'로 재지정.
P0-3	OAuth App 감사	Google Workspace에서 Client ID 110671459871-30f1spbu0hptbs60cb4vsmv79i7bbvqj... 사용 이력 확인 및 제거.

P0-4	배포 로그 검토	최근 14일간 Vercel 배포 파이프라인 로그에서 비정상 배포, 신규 환경 추가, 권한 변경 확인.
P0-5	Deployment Protection 강화	Deployment Protection을 Standard 이상으로 설정. 기존 bypass 토큰 즉시 교체.

7.2 일반 SaaS 사용 조직 대상 P1 (24 시간 내)

#	조치 항목	설명
P1-1	OAuth 앱 허용 정책 재검토	Google Workspace / Microsoft 365에서 'App access control'을 Allowlist 모드로 설정. 불필요한 AI 에이전트 OAuth 권한 일괄 철회.
P1-2	MFA 전면 적용	Vercel, GitHub, NPM, Google Workspace 모든 계정에 하드웨어 키(FIDO2) 기반 MFA 적용.
P1-3	AI 도구 인벤토리	조직 내 승인/비승인 AI 에이전트 도구 전수 조사. 데이터 접근 범위별 리스크 등급화.
P1-4	Secret Scanning 활성화	GitHub Advanced Security 또는 TruffleHog/Gitleaks로 레포지토리 전체 스캔. Push Protection 강제.
P1-5	NPM/GitHub Token 최소 권한화	Fine-grained PAT, Classic PAT → GitHub Apps + OIDC federation으로 전환. NPM 토큰은 Publish 전용 granular token 사용.

7.3 전략적 P2 (7 일 내, 근본 구조 변경)

#	조치 항목	설명
P2-1	Zero Trust 아키텍처 도입	모든 SaaS 접근에 대해 Identity + Device + Context 검증. Session risk 기반 재인증 정책.
P2-2	공급망 실사(Due Diligence)	AI SaaS 벤더에 SOC 2 Type II, ISO 27001, OAuth scope 최소화 증빙 요구.

P2-3	CI/CD 파이프라인 격리	빌드 환경을 개인 개발 계정과 분리된 독립 OIDC federation 기반 환경으로 이전.
P2-4	Incident Tabletop 훈련	Vercel 시나리오 기반 모의 대응 훈련 실시. 법무·홍보·기술 팀 통합 대응 절차 점검.

8. Web3, 가상화폐 산업에 미치는 영향

Vercel은 글로벌 Web3·DeFi 프런트엔드 배포 인프라의 사실상 표준으로 자리잡고 있다. 다수 DeFi 프로토콜, NFT 마켓플레이스, 스테이블코인 프로젝트 웹 인터페이스가 Vercel 호스팅 위에 구동된다. 본 사건은 암호화폐 생태계에 다음과 같은 특수한 리스크를 제기한다.

8.1 암호화폐 프로젝트 고유 리스크

리스크 유형	구체 시나리오
프런트엔드 변조 (Frontend Hijack)	공격자가 배포 토큰을 확보하면 DApp의 프런트엔드 JS를 변조하여 사용자 서명 요청을 공격자 지갑으로 리다이렉트. BadgerDAO 사건 (2021, 1.2억 달러 피해) 재현 가능.
RPC 엔드포인트 노출	Alchemy/Infura/QuickNode RPC URL이 '비민감' 환경 변수로 오분류될 경우, 공격자는 트래픽 모니터링, MEV 가로채기, 서비스 거부 공격을 수행 가능.
관리자 지갑 주소 유출	멀티시그·타임락 컨트랙트의 관리자 주소 목록이 환경 변수에 저장된 경우, 공격자는 타겟팅된 소셜 엔지니어링에 활용.
가격 오라클 API 키	Chainlink Data Feeds, CoinGecko Pro, CoinMarketCap API 키 탈취 시 가격 조작 또는 DoS로 청산 트리거 유발 가능.
Subgraph 접근 권한	The Graph 기반 인덱서 접근 키 노출 시 쿼리 비용 폭증 및 데이터 무결성 의심 공격 가능.
KYC/AML 데이터	CEX·RWA·스테이블코인 프로젝트의 KYC 벤더 연동 크리덴셜 노출 시 개인정보 2차 유출.

8.2 한국 Web3 생태계 관점

국내 Web3 프로젝트 중 상당수가 Vercel 기반 호스팅을 채택하고 있으며, 이는 DAXA 회원 거래소에 상장된 토큰의 프런트엔드 및 발행사 공식 웹사이트를 포함한다. 본 사건과 관련하여 특히 다음이 권고된다:

대상	권고사항
DAXA 회원 거래소	상장 심사 보안 점검 체크리스트에 '배포 인프라 SaaS 의존성 및 공급망 침해 대응 역량' 항목을 추가하는 것을 검토.
국내 Web3 발행사	Vercel·Cloudflare Pages·Netlify 등 프런트엔드 배포 SaaS 의존 현황 재점검. 환경 변수 분류 재감사 및 배포 토큰 로테이션.
스테이블코인 프로젝트	준비자산 증명(PoR) 대시보드가 Vercel 호스팅 기반인 경우, 데이터 피드 무결성 감사 및 WAF/SRI 적용 여부 확인.
법무·컴플라이언스	개인정보보호위원회 및 KoFIU 신고 대상 여부를 공급망 침해 관점에서 재평가. 특금법상 실질적 수탁자 판단 가능성 확인.

제언:
본 사건은 '인프라 공급망'이 프로토콜 감사 수준과 동일한 수준의 지속적 보안 검증을 요구한다는 것을 재확인시킨다.

Web3 프로젝트의 위험 모델링은 스마트 컨트랙트 감사에 더해 '호스팅·배포·CDN·DNS·월렛 연동 SDK' 전체 체인으로 확장되어야 한다.

9. 결론 및 전략적 시사점

Vercel 사건은 단일 기업의 보안 사고를 넘어, AI 시대 기업 보안의 구조적 변곡점(inflection point)을 드러낸다. 세 가지 전략적 교훈을 도출한다.

교훈 1 — 'AI 에이전트 = 최고 권한 내부자'

AI 워크플로우 도구는 업무 효율을 위해 이메일·파일·캘린더·CRM에 광범위한 OAuth 권한을 요구한다. 이는 사실상 '최고 권한을 가진 가상 직원'을 외부 벤더에 임대한 것과 동일하다. 해당 벤더 침해 시 폭발 반경은 조직 전체로 즉시 확장된다. AI 도입 결정에는 반드시 '제3자 SaaS 침해 시나리오'를 포함한 threat model 이 동반되어야 한다.

교훈 2 — '비-민감'이라는 분류는 존재하지 않는다

CEO가 공식 인정한 바와 같이, '비민감' 환경 변수가 권한 상승의 결정적 피벗이었다. 공격자는 '비민감' 데이터를 단편(fragment)으로 수집하여 공격 표면 지도를 완성한다. Zero Trust 관점에서 모든 환경 변수·모든 로그·모든 메타데이터는 잠재적 시크릿으로 취급되어야 한다.

교훈 3 — 공급망 공격은 '피라미드의 정점'을 노린다

ShinyHunters는 2025–2026년 내내 Salesloft, Gainsight, Mixpanel, Anodot, Context.ai 같은 SaaS '허브'를 타격하여 하위 수백-수천 기업에 파급 효과를 만들어 왔다. 공격자 경제성 관점에서 이는 합리적이다. 방어자 역시 자체 경계 방어를 넘어 '우리가 신뢰하는 벤더 생태계 전체의 보안 태세'를 정기적으로 평가하는 Third-Party Risk Management(TPRM) 프로그램을 갖춰야 한다.

최종 판단:

> 본 사건의 공식적 영향은 '제한된 수의 고객'으로 발표되었으나, NPM/GitHub 토큰 유출 여부에 따라 전 세계 Next.js 기반 애플리케이션의 배포 파이프라인 신뢰성에 대한 재평가가 필요할 수 있다.
>
> 최소 향후 30일간 Vercel·Context.ai 관련 추가 폭로 모니터링이 권고된다. 본 리포트는 추가 정보 확보 시 갱신될 예정이다.

10. 참고 문헌 및 출처

본 리포트는 2026년 4월 19-20일 공개된 1차 자료와 전문 보안 매체의 2차 자료를 교차 검증하여 작성되었다.

10.1 Vercel 공식 자료 및 1 차 언론

[1] *BleepingComputer,* "Vercel confirms breach as hackers claim to be selling stolen data". https://www.bleepingcomputer.com/news/security/vercel-confirms-breach-as-hackers-claim-to-be-selling-stolen-data/

[2] *The Hacker News,* "Vercel Breach Tied to Context AI Hack Exposes Limited Customer Credentials". https://thehackernews.com/2026/04/vercel-breach-tied-to-context-ai-hack.html

[3] *CCLeaks (Detailed Incident Rundown),* "Vercel Discloses April 2026 Breach of Internal Systems". https://ccleaks.com/news/vercel-april-2026-internal-systems-security-incident

[4] *Cryptika Cybersecurity,* "Vercel Confirms Data Breach — Hackers Claim Access to Internal Systems". https://www.cryptika.com/vercel-confirms-data-breach-hackers-claim-access-to-internal-systems/

[5] *The Information,* "Vercel Confirms Breach After Hackers List Stolen Data for $2M". https://www.theinformation.com/briefings/vercel-confirms-breach-hackers-list-stolen-data-2m

[6] *The Block,* "Web3 hosting backbone Vercel confirms breach as supposed hacker demands $2M ransom". https://www.theblock.co/post/398010/web3-hosting-backbone-vercel-confirms-breach-as-supposed-hacker-demands-2-million-ransom

[7] *Cryptopolitan,* "Cloud Dev platform breach tied to compromised AI tool raises alarm". https://www.cryptopolitan.com/vercel-breach-tied-to-compromised-ai-tool/

[8] *Startup Fortune,* "Vercel Breach Exposes AI Tool Supply Chain Risk Ahead of IPO". https://startupfortune.com/vercel-breach-exposes-ai-tool-supply-chain-risk-ahead-of-ipo/

[9] *Phemex News,* "Vercel Breach Tied to Compromised AI Tool OAuth App". https://phemex.com/news/article/vercel-security-breach-linked-to-compromised-thirdparty-ai-tool-74421

[10] *MEXC News,* "Vercel Security Breach Raises Concerns for Crypto Projects". https://www.mexc.co/news/1038486

10.2 ShinyHunters 위협 행위자 분석

[11] *Wikipedia (최신 갱신),* "ShinyHunters". https://en.wikipedia.org/wiki/ShinyHunters

[12] *Google Cloud Blog / Mandiant Threat Intelligence Group,* "Tracking the Expansion of ShinyHunters-Branded SaaS Data Theft". https://cloud.google.com/blog/topics/threat-intelligence/expansion-shinyhunters-saas-data-theft

[13] *Salesforce Ben,* "ShinyHunters 'Breach 400 Companies' via Salesforce Experience Cloud". https://www.salesforceben.com/shinyhunters-breach-400-companies-via-salesforce-experience-cloud/

[14] *Computer Weekly,* "ShinyHunters Salesforce cyber attacks explained". https://www.computerweekly.com/feature/ShinyHunters-Salesforce-cyber-attacks-explained-What-you-need-to-know

[15] *Help Net Security,* "ShinyHunters claims new campaign targeting Salesforce Experience Cloud sites". https://www.helpnetsecurity.com/2026/03/11/shinyhunters-salesforce-aura-data-breach/

[16] *Varonis,* "What Salesforce Organizations Need to Know About ShinyHunters and Vishing". https://www.varonis.com/blog/salesforce-vishing-threat-unc604

[17] *State of Surveillance,* "ShinyHunters Weaponized a Security Tool to Breach 400 Companies via Salesforce". https://stateofsurveillance.org/news/shinyhunters-salesforce-aura-400-companies-security-tool-weaponized-2026/

[18] *Hackread,* "ShinyHunters Claims Rockstar Games Snowflake Breach via Anodot". https://hackread.com/shinyhunters-rockstar-games-snowflake-breach-anodot/

[19] *Cybernews,* "Hackers threaten to leak over 9M Amtrak records via Salesforce". https://cybernews.com/security/hackers-threaten-amtrak-data-leak/

[20] *Mayhem Code,* "ShinyHunters Hacking Group Explained: 400 Companies Breached".

https://www.mayhemcode.com/2026/03/shinyhunters-hacking-group-explained.html

10.3 OAuth·Google Workspace 공급망 공격 배경

[21] *Red Canary,* "Breaking down a supply chain attack leveraging a malicious Google Workspace OAuth app". https://redcanary.com/blog/threat-detection/google-workspace-oauth-attack/

[22] *IronCore Labs,* "The Terrifying Takeaways from the Massive OAuth Breach (Salesloft Drift)". https://ironcorelabs.com/blog/2025/oath-token-tragedy/

[23] *The Hacker News,* "Google OAuth Vulnerability Exposes Millions via Failed Startup Domains". https://thehackernews.com/2025/01/google-oauth-vulnerability-exposes.html

[24] *Truffle Security,* "Millions of Accounts Vulnerable due to Google's OAuth Flaw". https://trufflesecurity.com/blog/millions-at-risk-due-to-google-s-oauth-flaw

[25] *Google Cloud Documentation,* "Best practices for mitigating compromised OAuth tokens for Google Cloud CLI". https://cloud.google.com/architecture/bps-for-mitigating-gcloud-oauth-tokens

[26] *Material Security,* "How Hackers Exploit Google Workspace Security". https://material.security/workspace-resources/google-workspace-security-gaps-hackers-exploit-and-how-to-patch-them-today

[27] *Kaspersky Daily,* "Why using Google OAuth in work applications is unsafe". https://www.kaspersky.com/blog/vulnerability-in-google-oauth/50286/

부록 A. 용어 정리

용어	정의
OAuth 2.0	사용자의 비밀번호 없이 제3자 애플리케이션이 사용자를 대신해 리소스에 접근하도록 하는 위임형 인가(authorization) 표준.
Refresh Token	Access Token 만료 시 재발급에 사용되는 장기 토큰. 탈취 시 MFA 우회 지속 접근 가능.
Environment Variable	애플리케이션 런타임에 주입되는 구성값. 시크릿(API 키, DB 비밀번호) 보관 수단으로 흔히 사용됨.
Supply Chain Attack	최종 표적이 아닌 해당 조직이 신뢰하는 제3자 벤더를 먼저 침해하여 간접 접근하는 공격.
BreachForums	RaidForums의 후신으로 알려진 영어권 주요 사이버 범죄 포럼. 다수 데이터 유출 판매 게시물이 게시됨.
DLS (Data Leak Site)	위협 행위자가 피해자의 유출 데이터 샘플을 공개 협박용으로 게시하는 다크웹 사이트.
Non-sensitive Variable	Vercel이 제공하는 환경 변수 분류 중 하나로, 암호화 저장되지 않아 열람이 가능. 본 사건의 핵심 피벗.
NPM/GitHub Token	각각 Node.js 패키지 매니저와 GitHub의 API 접근용 개인 엑세스 토큰. 탈취 시 악성 코드 배포 가능.

— 문서 끝 (End of Report) —

© 2026 Dennis Kim. · Cyber Threat Intelligence Division ·

본 리포트는 공개된 정보에 기반한 독립적 분석으로, 관련 조직의 공식 입장과 무관합니다.